Hub de Estudos

Apostilas, exercícios e simulados

JSON



HTTP



Segurança



API

Desenvolvimento de APIs para a Web

REST, Next.js, Prisma e segurança

Desenvolvimento de APIs para a Web

REST, Next.js, Prisma e segurança

Hub de Estudos

Apostilas, exercícios e simulados

2026

Todos os direitos reservados. Nenhuma parte desta publicação pode ser reproduzida, armazenada ou transmitida de qualquer forma, ou por qualquer meio, sem autorização prévia.

Desenvolvido por TecPro Tecnologias.

Sumário

Capítulo 1 – APIs e Web Services **4**
1.1 O que é uma API 4
1.2 Cliente, servidor e o protocolo HTTP 4
1.3 A anatomia de uma URL 6
1.4 Serviços web com SOAP 6
1.5 APIs REST 7
1.6 GraphQL 7
1.7 Outros estilos de comunicação 8
1.8 Comparando SOAP, REST e GraphQL 8
1.9 Consultando uma API pública 9
1.10 O projeto da apostila: a API do TaskFlow 10
Erros Comuns 11

Capítulo 2 – Design RESTful e métodos HTTP **12**
2.1 Recursos e representações 12
2.2 As restrições do REST 12
2.3 Boas URLs 13
2.4 Os métodos HTTP 14
2.5 Métodos seguros e idempotentes 14
2.6 PUT ou PATCH? 15
2.7 Os códigos de status mais usados 15
2.8 Filtros, ordenação e paginação 16
2.9 Versionamento 17
2.10 HATEOAS e o modelo de maturidade 17
2.11 Projetando a API do TaskFlow 18
Erros Comuns 19

Capítulo 1 – APIs e Web Services

Quando você abre o aplicativo do banco e vê o seu saldo, quando um site de compras calcula o frete a partir do CEP ou quando um sistema emite uma nota fiscal eletrônica, há sempre dois programas conversando: um que pede uma informação e outro que a entrega. Essa conversa acontece por meio de uma **API**. Neste capítulo você vai entender o que é uma API, como funciona o protocolo HTTP, que transporta essas conversas na web, e quais são os principais estilos de serviço web: SOAP, REST e GraphQL. No final, vai consultar uma API pública de verdade e conhecer o projeto que será construído ao longo da apostila.

1.1 O que é uma API

API é a sigla de *Application Programming Interface*, ou interface de programação de aplicações. É um conjunto de regras que define como um programa pode pedir algo a outro: quais pedidos existem, que dados cada pedido precisa receber e o que vem de volta.

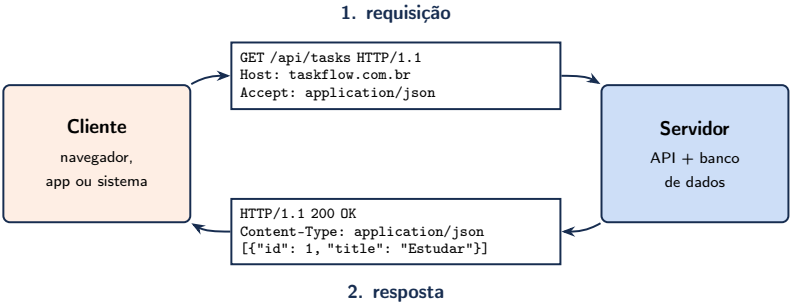
Uma comparação comum é a do restaurante. O cliente não entra na cozinha: ele consulta o cardápio e faz o pedido ao garçom, que leva o pedido à cozinha e traz o prato. O cardápio é o **contrato** da API (o que pode ser pedido), o garçom é a API, e a cozinha é o sistema que faz o trabalho. O cliente não precisa saber como a cozinha funciona, e a cozinha pode mudar de fogão sem que o cliente perceba, desde que o cardápio continue o mesmo.

Esse é o grande valor de uma API: ela **separa quem usa de quem implementa**. Um mesmo servidor pode atender, ao mesmo tempo, o site, o aplicativo de celular e o sistema de um parceiro, todos usando o mesmo contrato.

O termo API é amplo. As funções de uma biblioteca, como o `readFile` do Node.js, também formam uma API. Nesta apostila, porém, o foco são as **APIs web**: aquelas acessadas pela rede, usando o protocolo HTTP. Quando essas APIs são oferecidas por um sistema para ser usadas por outros sistemas, também são chamadas de **serviços web** (*web services*).

1.2 Cliente, servidor e o protocolo HTTP

Toda conversa com uma API web segue o modelo **cliente-servidor**: o **cliente** envia uma **requisição** (*request*) e o **servidor** devolve uma **resposta** (*response*). O cliente pode ser um navegador, um aplicativo de celular ou outro servidor. As regras dessa troca são as do **HTTP** (*HyperText Transfer Protocol*), o mesmo protocolo que o navegador usa para carregar páginas.



o servidor não guarda memória entre uma requisição e outra (sem estado)

Uma requisição HTTP tem quatro partes:

- o **método**, que diz o que o cliente quer fazer: `GET` para buscar, `POST` para criar, `PUT` e `PATCH` para alterar, `DELETE` para excluir;
- a **URL**, que diz em que recurso a ação será feita, como `/api/tasks`;
- os **cabeçalhos** (*headers*), pares nome e valor com informações extras, como o formato aceito na resposta;
- o **corpo** (*body*), opcional, com os dados enviados, por exemplo os campos de uma tarefa nova.

A resposta tem três: o **código de status**, um número que resume o resultado (`200` deu certo, `404` não encontrado, `500` erro no servidor), os **cabeçalhos** e o **corpo**, com os dados pedidos. Por baixo de tudo, requisição e resposta são apenas texto. Veja como fica a criação de uma tarefa:

```
POST /api/tasks HTTP/1.1
Host: taskflow.com.br
Content-Type: application/json

{"title": "Estudar HTTP", "priority": "HIGH"}
```

```
HTTP/1.1 201 Created
Content-Type: application/json
Location: /api/tasks/42

{"id": 42, "title": "Estudar HTTP", "priority": "HIGH"}
```

A linha em branco separa os cabeçalhos do corpo. O cabeçalho `Content-Type` informa o formato do corpo; aqui, `application/json`. O status `201 Created` indica que um recurso novo foi criado, e o cabeçalho `Location` diz onde ele pode ser encontrado. Os métodos e os códigos de status são estudados em detalhe nos Capítulos 2 e 8.

Uma característica essencial do HTTP é ser **sem estado** (*stateless*): cada requisição é independente, e o servidor não se lembra das anteriores. Se o servidor precisa saber quem está pedindo, a própria requisição tem de trazer essa informação, normalmente

um **token** em um cabeçalho. É assim que funciona o login em APIs, assunto do Capítulo 9.

1.3 A anatomia de uma URL

A URL (*Uniform Resource Locator*) identifica onde está o recurso. Cada parte tem uma função:

```
https://api.taskflow.com.br:443/v1/tasks?status=DONE&page=2
```

Parte	Exemplo	Função
protocolo	`https`	como a conversa acontece; o `s` indica conexão criptografada
domínio	`api.taskflow.com.br`	o nome do servidor
porta	`443`	a "porta de entrada"; 443 é o padrão do HTTPS e costuma ser omitida
caminho	`/v1/tasks`	o recurso dentro do servidor
query string	`?status=DONE&page=2`	parâmetros extras, como filtros e paginação, em pares nome=valor separados por `&`

Na *query string*, espaços e acentos não podem aparecer como são: eles são codificados, e "São Paulo" vira `S%C3%A3o%20Paulo`. O `fetch` e as bibliotecas de HTTP cuidam disso com `encodeURIComponent` ou com a classe `URLSearchParams`.

1.4 Serviços web com SOAP

Os primeiros serviços web populares, no início dos anos 2000, usavam o **SOAP** (*Simple Object Access Protocol*), um protocolo padronizado pelo W3C. No SOAP, toda mensagem é um documento **XML** com uma estrutura fixa, o **envelope**, e o serviço é descrito em um arquivo **WSDL** (*Web Services Description Language*), também em XML, que lista as operações, os parâmetros e os tipos de cada uma. A partir do WSDL, ferramentas geram automaticamente o código do cliente.

```
<soap:Envelope
    xmlns:soap="http://www.w3.org/2003/05/soap-envelope"
    xmlns:t="http://taskflow.com.br/ws">
  <soap:Header/>
  <soap:Body>
    <t:BuscarTarefa>
      <t:id>42</t:id>
    </t:BuscarTarefa>
  </soap:Body>
</soap:Envelope>
```

Repare que a operação, `BuscarTarefa`, aparece dentro da mensagem. No SOAP, todas as chamadas costumam ir para uma mesma URL, quase sempre com o método `POST`, e é o conteúdo do envelope que diz o que fazer. O padrão também define como devolver

erros (o elemento `Fault`) e tem extensões para segurança e transações, como o WS-Security.

O SOAP é verboso e rígido, mas essa rigidez é justamente o que alguns sistemas querem: um contrato formal, validado automaticamente. Por isso ele continua presente em bancos, seguradoras e em sistemas de governo. No Brasil, a emissão da Nota Fiscal Eletrônica (NF-e) é feita por serviços web SOAP das secretarias da Fazenda.

1.5 APIs REST

O **REST** (*Representational State Transfer*) não é um protocolo, e sim um **estilo de arquitetura**, descrito por Roy Fielding em sua tese de doutorado, em 2000. A ideia central é organizar a API em torno de **recursos**, as "coisas" do sistema (tarefas, usuários, pedidos), cada um identificado por uma URL, e usar os **métodos do próprio HTTP** para dizer o que fazer com eles:

```
GET    /api/tasks       lista as tarefas
POST   /api/tasks       cria uma tarefa
GET    /api/tasks/42    busca a tarefa 42
PATCH  /api/tasks/42    altera parte da tarefa 42
DELETE /api/tasks/42    exclui a tarefa 42
```

O servidor devolve uma **representação** do recurso, hoje quase sempre em **JSON**, um formato de texto leve e fácil de ler tanto por pessoas quanto por programas:

```
{
  "id": 42,
  "title": "Estudar HTTP",
  "status": "PENDING",
  "priority": "HIGH",
  "dueDate": "2026-11-20"
}
```

Compare com o SOAP: em vez de uma operação `BuscarTarefa` escrita dentro de um envelope, o REST usa `GET` na URL da tarefa. As regras do estilo, como a ausência de estado e o uso de URLs para identificar recursos, são o tema do Capítulo 2. Por ser simples, usar o HTTP como ele foi pensado e funcionar bem com JavaScript, o REST se tornou o estilo dominante nas APIs web, e é o estilo usado nesta apostila.

1.6 GraphQL

O **GraphQL** foi criado pelo Facebook em 2012 e aberto ao público em 2015. Ele é uma **linguagem de consulta** para APIs: em vez de várias URLs, há um único endereço, normalmente `/graphql`, e o cliente envia uma consulta dizendo exatamente quais campos quer receber.

```
query {
  usuario(id: 7) {
    nome
    tarefas(status: PENDING) {
```

```
      title
      dueDate
    }
  }
}
```

```
{
  "data": {
    "usuario": {
      "nome": "Ana",
      "tarefas": [
        { "title": "Estudar HTTP", "dueDate": "2026-11-20" }
      ]
    }
  }
}
```

A resposta tem o mesmo formato da consulta. Isso resolve dois problemas comuns do REST: receber campos demais, que o cliente não vai usar (*over-fetching*), e precisar de várias requisições para montar uma tela, como uma para o usuário e outra para as tarefas dele (*under-fetching*). Em troca, o servidor fica mais complexo, e recursos simples do HTTP, como o *cache* por URL, deixam de funcionar sozinhos. O GraphQL brilha em aplicações com telas muito variadas, como redes sociais; para a maioria das APIs, o REST continua mais simples.

1.7 Outros estilos de comunicação

Três outras formas de comunicação aparecem com frequência ao lado das APIs:

- **gRPC**: criado pelo Google, usa o HTTP/2 e um formato binário, o *Protocol Buffers*, muito mais compacto que o JSON. É comum na comunicação entre servidores de uma mesma empresa, em que o desempenho importa mais que a facilidade de leitura.
- **WebSocket**: abre uma conexão que fica aberta, e o servidor pode enviar dados ao cliente a qualquer momento, sem esperar uma requisição. É a base de chats, placares ao vivo e notificações em tempo real.
- **Webhook**: é o caminho inverso de uma API. Em vez de o seu sistema perguntar de tempos em tempos "o pagamento foi aprovado?", o serviço de pagamento faz uma requisição `POST` para uma URL do seu sistema assim que o pagamento é aprovado.

1.8 Comparando SOAP, REST e GraphQL

	SOAP	REST	GraphQL
o que é	protocolo	estilo de arquitetura	linguagem de consulta
formato	XML (envelope)	qualquer um; quase sempre JSON	JSON
endereços	uma URL por serviço	uma URL por recurso	uma URL só
operação indicada	no envelope	pelo método HTTP	na consulta
contrato	WSDL, obrigatório	opcional (OpenAPI, Capítulo 10)	esquema, obrigatório
uso típico	bancos, governo, sistemas legados	APIs públicas e a maioria dos sistemas web	telas com dados muito variados

Nenhum estilo é melhor em tudo. A escolha depende de quem vai usar a API, do tipo de dado e das exigências do sistema. Um mesmo produto pode, inclusive, usar mais de um: REST para o aplicativo, SOAP para falar com o sistema fiscal e WebSocket para as notificações.

1.9 Consultando uma API pública

A melhor forma de entender uma API é usar uma. O **ViaCEP** é um serviço gratuito que devolve o endereço de um CEP e não exige cadastro. Como a consulta usa o método `GET`, basta colar a URL no navegador:

```
https://viacep.com.br/ws/01001000/json/
```

Pelo terminal, a ferramenta `curl` faz a mesma requisição e mostra a resposta. Ela já vem instalada no Windows 10 e 11, no macOS e no Linux; no PowerShell, digite `curl.exe`. A opção `-i` mostra também a linha de status e os cabeçalhos:

```
$ curl -i https://viacep.com.br/ws/01001000/json/
HTTP/1.1 200 OK
Content-Type: application/json; charset=utf-8

{
  "cep": "01001-000",
  "logradouro": "Praça da Sé",
  "complemento": "lado ímpar",
  "bairro": "Sé",
  "localidade": "São Paulo",
  "uf": "SP",
  "ddd": "11"
}
```

A resposta real tem mais campos e cabeçalhos; aqui aparecem só os principais. Em um programa, a requisição é feita com o `fetch`, que existe no navegador e, desde a versão 18, também no Node.js:

```
// cep.mjs  -- rode com: node cep.mjs
const cep = "01001000";
const url = `https://viacep.com.br/ws/${cep}/json/`;

const resposta = await fetch(url);
console.log(resposta.status);     // 200

const endereco = await resposta.json();
console.log(`${endereco.logradouro}, ${endereco.localidade}`);
// Praça da Sé, São Paulo
```

O `fetch` devolve uma *Promise* com a resposta; `resposta.status` é o código de status, e `resposta.json()` lê o corpo e o converte em um objeto JavaScript. Troque `json` por `xml` no fim da URL e o mesmo serviço responde em XML, assunto do Capítulo 5.

Experimente também um CEP que não existe, como `99999999`. O ViaCEP responde com status `200` e o corpo `{"erro": "true"}`. É uma escolha de projeto discutível: o Capítulo 8 mostra por que, em uma API REST, o mais adequado seria o status `404`.

1.10 O projeto da apostila: a API do TaskFlow

Ao longo da apostila, você vai construir a API do **TaskFlow**, um gerenciador de tarefas em que cada pessoa cria uma conta e organiza as próprias tarefas. A cada capítulo, a API ganha uma parte nova, até ser publicada na internet com domínio próprio. As ferramentas são as mesmas usadas por empresas no dia a dia:

- **Next.js** com **TypeScript**, para criar as rotas da API (Capítulos 3 e 4);
- **PostgreSQL** na nuvem, com o NeonDB, e o **Prisma** para acessar o banco (Capítulos 3 e 7);
- **Zod**, para validar os dados recebidos (Capítulo 6);
- **JWT**, para a autenticação (Capítulo 9);
- **Vitest**, para os testes automatizados (Capítulo 11);
- **Vercel**, para a publicação (Capítulo 12).

Ao final, a API terá estes *endpoints*, ou seja, as combinações de método e URL que ela atende:

Método	URL	O que faz
`POST`	`/api/auth/register`	cria uma conta
`POST`	`/api/auth/login`	entra e recebe um token
`GET`	`/api/tasks`	lista as tarefas de quem está logado, com filtros
`POST`	`/api/tasks`	cria uma tarefa
`GET`	`/api/tasks/:id`	busca uma tarefa
`PATCH`	`/api/tasks/:id`	altera uma tarefa
`DELETE`	`/api/tasks/:id`	exclui uma tarefa

O `:id` indica uma parte variável da URL: `/api/tasks/42` é a tarefa 42. Para acompanhar, você vai precisar do Node.js (versão 20 ou mais nova), do VS Code e de uma conta gratuita no GitHub, que também serve para entrar no NeonDB e na Vercel.

Erros Comuns

- **Achar que API é sinônimo de REST.** REST é um estilo; SOAP, GraphQL e gRPC também são formas de construir APIs.
- **Achar que o servidor "lembra" do cliente.** O HTTP é sem estado: cada requisição precisa trazer tudo o que o servidor precisa saber, inclusive quem está pedindo.
- **Confundir a URL com o *endpoint*.** O mesmo caminho, `/api/tasks`, é um *endpoint* com `GET` (listar) e outro com `POST` (criar).
- **Esquecer o `await` no `fetch`.** Sem ele, a variável guarda uma *Promise*, e não a resposta. O mesmo vale para `resposta.json()`.
- **Confiar apenas no status.** Algumas APIs, como o ViaCEP com um CEP inexistente, respondem `200` e indicam o erro no corpo. Leia a documentação de cada API.
- **Colocar acentos e espaços direto na *query string*.** Use `encodeURIComponent` ou `URLSearchParams` para montar os parâmetros.

Capítulo 2 – Design RESTful e métodos HTTP

No Capítulo 1, o REST apareceu como o estilo que organiza a API em torno de recursos e usa os métodos do HTTP. Mas dizer que uma API "é REST" não basta: duas APIs REST podem ser fáceis ou difíceis de usar dependendo de como foram projetadas. Neste capítulo você vai conhecer as regras do estilo REST, aprender a escolher boas URLs, entender o significado preciso de cada método HTTP, inclusive os conceitos de método seguro e idempotente, e ver as convenções de filtros, paginação e versionamento. No final, vai projetar no papel a API completa do TaskFlow, antes de escrever qualquer código.

2.1 Recursos e representações

Em REST, tudo gira em torno de **recursos**: as "coisas" que o sistema guarda e que fazem sentido para quem usa a API. No TaskFlow, os recursos são os usuários e as tarefas. Em uma loja, seriam produtos, clientes e pedidos.

Cada recurso tem um identificador único, a sua **URI** (*Uniform Resource Identifier*), como `/api/tasks/42`. A URI é o "endereço" do recurso, e não muda conforme a ação: buscar, alterar e excluir a tarefa 42 usam todas a mesma URI, com métodos diferentes.

O cliente nunca recebe o recurso em si, que está guardado no banco de dados, e sim uma **representação** dele: um retrato em algum formato, quase sempre JSON. O mesmo recurso pode ter várias representações. O cliente diz qual prefere com o cabeçalho `Accept`, e o servidor informa qual enviou com o `Content-Type`:

```
GET /api/tasks/42 HTTP/1.1
Accept: application/json

HTTP/1.1 200 OK
Content-Type: application/json

{"id": 42, "title": "Estudar REST", "status": "PENDING"}
```

Essa escolha do formato pelos cabeçalhos se chama **negociação de conteúdo** e volta no Capítulo 5, com JSON e XML.

2.2 As restrições do REST

Roy Fielding definiu o REST como um conjunto de **restrições**: regras que, quando seguidas, dão ao sistema escalabilidade, simplicidade e independência entre as partes. Uma API é RESTful quando respeita essas regras:

Restrição	O que significa
cliente-servidor	interface e dados ficam separados; o site, o aplicativo e o servidor evoluem de forma independente
sem estado	cada requisição traz tudo o que o servidor precisa; ele não guarda sessão entre uma e outra
cache	a resposta diz se pode ser guardada e reaproveitada, o que poupa requisições
interface uniforme	recursos identificados por URIs, manipulados por representações, com mensagens que se explicam sozinhas
sistema em camadas	o cliente não sabe se fala direto com o servidor ou com intermediários, como um balanceador de carga ou uma CDN
código sob demanda (opcional)	o servidor pode enviar código para o cliente executar, como um *script*

A restrição **sem estado** é a que mais influencia o projeto. Como o servidor não guarda nada entre as requisições, qualquer servidor de um grupo pode atender qualquer requisição. É isso que permite colocar dez cópias da API atrás de um balanceador de carga quando o número de usuários cresce. O preço é que o cliente precisa mandar, a cada requisição, a sua identificação, normalmente um *token*.

2.3 Boas URLs

A URL é a primeira coisa que o desenvolvedor vê da sua API, e um bom padrão torna a API previsível: quem aprendeu a listar tarefas consegue adivinhar como listar usuários. As convenções mais aceitas são estas:

- **Use substantivos, nunca verbos.** A ação já está no método HTTP. `POST /tasks`, e não `POST /criarTarefa`.
- **Use o plural para coleções.** `/tasks` é a coleção; `/tasks/42` é um item dela. O mesmo nome serve aos dois casos.
- **Mostre a hierarquia quando ela existe.** As tarefas do usuário 7 ficam em `/users/7/tasks`. Evite passar de dois níveis: `/users/7/tasks/42/comments/3` já é difícil de manter.
- **Use letras minúsculas e hífens.** `/task-categories`, e não `/TaskCategories` nem `/task_categories`. Partes da URL podem diferenciar maiúsculas de minúsculas, o que confunde.
- **Filtros vão na *query string*.** `/tasks?status=DONE`, e não `/tasks/done`: a tarefa concluída continua sendo uma tarefa.
- **Não exponha detalhes de implementação.** Nada de `/tasks.php` ou `/api/tabela_tarefas`. Se a tecnologia mudar, a URL continua a mesma.

Evite	Prefira
`GET /getTasks`	`GET /tasks`
`POST /tasks/create`	`POST /tasks`
`GET /task/42`	`GET /tasks/42`
`POST /tasks/42/delete`	`DELETE /tasks/42`
`GET /tasks/pendentes`	`GET /tasks?status=PENDING`
`GET /tasksDoUsuario?id=7`	`GET /users/7/tasks`

Há casos em que uma ação não se encaixa bem em criar, ler, alterar ou excluir, como "reenviar o e-mail de confirmação". A saída usual é tratar a ação como um subrecurso e usar `POST`: `POST /users/7/confirmation-email`. Use isso com moderação; na maioria das vezes, a ação pode ser expressa como alteração de um campo, como `PATCH /tasks/42` com `{"status": "DONE"}` em vez de `POST /tasks/42/concluir`.

2.4 Os métodos HTTP

O método diz **o que** o cliente quer fazer com o recurso indicado pela URL. Cada método tem um significado definido pela especificação do HTTP (a RFC 9110), e respeitá-lo é o que permite a navegadores, *caches* e bibliotecas tratarem a sua API corretamente.

Método	Uso	Corpo	Seguro	Idempotente
`GET`	buscar um recurso ou uma coleção	não	sim	sim
`POST`	criar um recurso em uma coleção	sim	não	não
`PUT`	substituir o recurso inteiro	sim	não	sim
`PATCH`	alterar parte do recurso	sim	não	não*
`DELETE`	excluir o recurso	não	não	sim
`HEAD`	como o GET, mas só os cabeçalhos	não	sim	sim
`OPTIONS`	perguntar quais métodos a URL aceita	não	sim	sim

* O PATCH pode ser idempotente, dependendo de como a alteração é descrita (Seção 2.6).

O `HEAD` serve, por exemplo, para saber o tamanho de um arquivo pelo cabeçalho `Content-Length` sem baixá-lo. O `OPTIONS` é usado automaticamente pelo navegador antes de certas requisições entre domínios diferentes, no mecanismo chamado CORS, estudado no Capítulo 12.

2.5 Métodos seguros e idempotentes

Duas propriedades da tabela anterior merecem atenção, porque são cobradas com frequência e evitam erros graves.

Um método é **seguro** quando não altera nada no servidor: ele só lê. `GET`, `HEAD` e `OPTIONS` são seguros. Por isso, navegadores e robôs de busca seguem links (que fazem `GET`) livremente, e ferramentas de *cache* guardam as respostas. Uma API que exclui algo em um `GET`, como `GET /tasks/42/delete`, corre o risco de ver os dados sumirem quando um robô ou uma pré-visualização de link visitar a URL.

Um método é **idempotente** quando repetir a mesma requisição várias vezes deixa o servidor no mesmo estado que fazê-la uma vez só. Pense em um elevador: apertar o botão do 5º andar uma ou dez vezes leva ao mesmo lugar.

- `DELETE /tasks/42` é idempotente: depois da primeira vez, a tarefa já não existe, e as repetições não mudam nada. A resposta pode mudar (a segunda recebe `404`), mas o **estado** do servidor é o mesmo.
- `PUT /tasks/42` com a tarefa completa é idempotente: gravar os mesmos dados de novo dá no mesmo.

- `POST /tasks` **não** é idempotente: cada repetição cria uma tarefa nova.

Isso importa na prática por causa das falhas de rede. Se o cliente envia uma requisição e a conexão cai antes da resposta, ele não sabe se o servidor a recebeu. Com um método idempotente, basta repetir. Com um `POST`, repetir pode criar um pedido em dobro, e é por isso que sites de compra pedem para você não apertar o botão "Pagar" duas vezes. APIs de pagamento resolvem o problema com uma **chave de idempotência**: o cliente gera um código único e o envia em um cabeçalho, como `Idempotency-Key`; se o servidor já processou aquele código, devolve o resultado anterior em vez de cobrar de novo.

2.6 PUT ou PATCH?

Os dois alteram um recurso existente, mas de formas diferentes. O `PUT` **substitui** o recurso inteiro pela representação enviada; o `PATCH` aplica uma **alteração parcial**. Considere a tarefa 42:

```
{"id": 42, "title": "Estudar REST",
 "status": "PENDING", "priority": "HIGH"}
```

Para marcá-la como concluída, o `PATCH` envia só o que muda:

```
PATCH /api/tasks/42
{"status": "DONE"}
```

Com `PUT`, é preciso enviar a tarefa completa. Se o cliente mandar só `{"status": "DONE"}`, um servidor que segue a regra à risca entende que o título e a prioridade foram retirados:

```
PUT /api/tasks/42
{"title": "Estudar REST", "status": "DONE", "priority": "HIGH"}
```

Na prática, o `PATCH` é o mais usado para edições, porque os formulários costumam alterar poucos campos e a requisição fica menor. Um `PATCH` como o acima, que define valores, é idempotente. Já um `PATCH` que descreve uma operação relativa, como "some 1 ao contador de visualizações", não é: cada repetição soma de novo. Por isso a especificação não garante a idempotência do `PATCH`. A API do TaskFlow usa `PATCH` para editar tarefas.

2.7 Os códigos de status mais usados

O código de status resume o resultado em três dígitos, e o primeiro indica a família:

Família	Significado
`1xx`	informação: a requisição foi recebida e continua em processamento (raro em APIs)
`2xx`	sucesso
`3xx`	redirecionamento: o recurso está em outro lugar
`4xx`	erro do cliente: a requisição tem algum problema
`5xx`	erro do servidor: a requisição estava certa, mas o servidor falhou

A distinção entre `4xx` e `5xx` é importante: com `4xx`, o cliente precisa corrigir algo antes de tentar de novo; com `5xx`, a mesma requisição pode funcionar mais tarde. Os códigos que aparecem em quase toda API são estes, e o Capítulo 8 trata de como escolher e montar as respostas de erro:

Código	Quando usar
`200 OK`	sucesso com corpo na resposta: GET, PUT, PATCH
`201 Created`	POST que criou um recurso; envie o cabeçalho `Location` com a URI dele
`204 No Content`	sucesso sem corpo, típico do DELETE
`400 Bad Request`	dados malformados ou inválidos
`401 Unauthorized`	falta autenticação, ou o *token* é inválido
`403 Forbidden`	autenticado, mas sem permissão para aquele recurso
`404 Not Found`	o recurso não existe
`405 Method Not Allowed`	a URL existe, mas não aceita aquele método
`409 Conflict`	conflito com o estado atual, como um e-mail já cadastrado
`500 Internal Server Error`	falha inesperada no servidor

2.8 Filtros, ordenação e paginação

Uma coleção pode ter milhares de itens, e devolver tudo de uma vez deixa a API lenta e a resposta enorme. As operações sobre coleções usam a *query string*, com nomes que sigam sempre o mesmo padrão:

```
GET /api/tasks?status=PENDING&priority=HIGH
GET /api/tasks?search=relatorio
GET /api/tasks?sort=dueDate
GET /api/tasks?sort=-createdAt
GET /api/tasks?page=2&limit=10
```

Os filtros usam o nome do próprio campo. A busca por texto costuma usar `search` ou `q`. Na ordenação, uma convenção comum é o sinal de menos indicar a ordem decrescente: `-createdAt` lista as mais recentes primeiro. Na **paginação**, `page` indica a página e `limit` quantos itens vêm em cada uma. A resposta deve informar ao cliente quanto falta, para que ele saiba se mostra o botão "próxima página":

```
{
  "data": [
    {"id": 11, "title": "Revisar capítulo 1"},
    {"id": 12, "title": "Ler sobre PATCH"}
  ],
  "meta": {"page": 2, "limit": 10, "total": 37, "totalPages": 4}
}
```

Os dados ficam em `data` e as informações da paginação em `meta`. Esse "envelope" é uma convenção, e não uma regra do REST, mas usar sempre o mesmo formato facilita a vida de quem consome a API. Defina também um `limit` máximo, como 100: sem ele, um cliente pode pedir `limit=1000000` e sobrecarregar o servidor.

A paginação por número de página é simples, mas tem um defeito: se uma tarefa nova é criada enquanto o usuário navega, os itens "escorregam" e um deles aparece em duas páginas. APIs com muito movimento, como as de redes sociais, usam a paginação por **cursor**: a resposta traz um código que aponta para o último item visto, e a próxima página começa depois dele (`?cursor=abc123`).

2.9 Versionamento

Uma API publicada tem clientes que dependem dela, e mudar o contrato pode quebrá-los. Mudanças que **não quebram** os clientes, como acrescentar um campo novo na resposta ou um *endpoint* novo, podem ser feitas a qualquer momento. Mudanças que **quebram**, como renomear ou remover um campo, mudar o tipo de um valor ou tornar obrigatório um campo que era opcional, exigem uma nova **versão** da API.

A forma mais comum e mais visível é colocar a versão na URL:

```
GET /api/v1/tasks
GET /api/v2/tasks
```

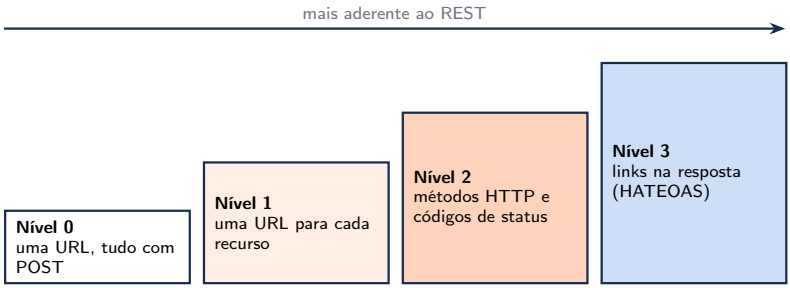
Outra opção é indicar a versão em um cabeçalho, deixando as URLs limpas. Qualquer que seja a escolha, a versão antiga deve continuar funcionando por um tempo, com aviso aos clientes, até ser desativada. A API do TaskFlow é pequena e tem um único cliente no início, então começa sem versão; se um dia precisar de uma segunda versão, ela nasce em `/api/v2`.

2.10 HATEOAS e o modelo de maturidade

A última parte da restrição de interface uniforme tem um nome comprido: **HATEOAS** (*Hypermedia as the Engine of Application State*). A ideia é que a resposta traga **links** para as ações possíveis, como uma página web traz links para as próximas páginas. O cliente descobre o que pode fazer navegando, sem precisar conhecer todas as URLs de antemão:

```
{
  "id": 42,
  "title": "Estudar REST",
  "status": "PENDING",
  "_links": {
    "self":     {"href": "/api/tasks/42"},
    "complete": {"href": "/api/tasks/42", "method": "PATCH"},
    "delete":   {"href": "/api/tasks/42", "method": "DELETE"}
  }
}
```

Leonard Richardson propôs um modelo que classifica as APIs em quatro níveis, conforme o quanto aproveitam as ideias do REST:



a maioria das APIs REST do mercado está no nível 2, como a API do TaskFlow

No **nível 0**, a API usa o HTTP só como transporte: uma URL e tudo com `POST`, como no SOAP. No **nível 1**, cada recurso tem a sua URL. No **nível 2**, os métodos e os códigos de status são usados com o seu significado. O **nível 3** acrescenta os links. A grande maioria das APIs chamadas de REST está no nível 2, que já traz quase todos os benefícios práticos, e é o nível da API do TaskFlow.

2.11 Projetando a API do TaskFlow

Antes de escrever código, uma boa prática é desenhar a API: listar os recursos, os *endpoints*, o que cada um recebe e o que devolve. Esse desenho serve de contrato entre quem faz o servidor e quem faz o cliente, que podem trabalhar ao mesmo tempo.

O TaskFlow tem dois recursos. O **usuário** tem nome, e-mail e senha. A **tarefa** tem título, descrição opcional, situação (`PENDING`, `IN_PROGRESS` ou `DONE`), prioridade (`LOW`, `MEDIUM` ou `HIGH`) e data de vencimento opcional, e pertence a um usuário. Cada pessoa só enxerga as próprias tarefas, então a URL não precisa trazer o usuário: o servidor descobre quem é pelo *token*. Por isso a API usa `/api/tasks`, e não `/api/users/7/tasks`.

Endpoint	Recebe	Sucesso
`POST /api/auth/register`	nome, e-mail e senha	`201` e o usuário, sem a senha
`POST /api/auth/login`	e-mail e senha	`200` e o *token*
`GET /api/tasks`	filtros: `status`, `priority`, `search`, `sort`, `page`, `limit`	`200`, `data` e `meta`
`POST /api/tasks`	título e, opcionalmente, os demais campos	`201`, a tarefa e `Location`
`GET /api/tasks/:id`	–	`200` e a tarefa
`PATCH /api/tasks/:id`	os campos que mudam	`200` e a tarefa atualizada
`DELETE /api/tasks/:id`	–	`204`, sem corpo

Os erros também fazem parte do contrato. Todo *endpoint* de tarefas responde `401` sem um *token* válido; os que recebem dados respondem `400` quando eles são inválidos; os que usam `:id` respondem `404` quando a tarefa não existe **ou pertence a outra pessoa**. Responder `404`, e não `403`, no segundo caso evita revelar que existe uma tarefa com aquele número. O cadastro responde `409` quando o e-mail já está em uso. Um exemplo completo de criação:

```
POST /api/tasks HTTP/1.1
Authorization: Bearer eyJhbGciOi...
Content-Type: application/json

{"title": "Entregar o trabalho", "priority": "HIGH",
 "dueDate": "2026-12-01"}
```

```
HTTP/1.1 201 Created
Location: /api/tasks/cm3x9k2a0001
Content-Type: application/json

{
  "id": "cm3x9k2a0001",
  "title": "Entregar o trabalho",
  "description": null,
  "status": "PENDING",
  "priority": "HIGH",
  "dueDate": "2026-12-01T00:00:00.000Z",
  "createdAt": "2026-10-16T14:05:12.000Z"
}
```

Repare em três detalhes. O servidor preencheu sozinho os campos que o cliente não enviou: `status` começou como `PENDING`, e `description` veio como `null`. O identificador não é um número sequencial, e sim um texto aleatório (um *cuid*), gerado pelo banco no Capítulo 3; isso impede que alguém adivinhe quantas tarefas existem ou tente os números em sequência. E as datas vêm no formato ISO 8601, com o fuso UTC indicado pelo `Z`, assunto do Capítulo 5.

Erros Comuns

- **Verbos na URL.** `/getTasks` ou `/deleteTask/42` repetem o que o método já diz. Use substantivos e deixe a ação para o método.
- **Alterar dados com GET.** O GET deve ser seguro. Robôs, pré-visualizações de links e *caches* fazem GET sem pedir licença.
- **Usar POST para tudo.** A API funciona, mas perde o significado dos métodos, a idempotência e o *cache*: é o nível 0 de maturidade.
- **Mandar só parte dos campos em um PUT.** O PUT substitui o recurso inteiro. Para alterar só alguns campos, use PATCH.
- **Responder 200 para tudo, inclusive erros.** O cliente precisa ler o corpo para saber se deu certo. Use os códigos de status com o seu significado.
- **Confundir 401 e 403.** 401: "não sei quem é você". 403: "sei quem é você, mas você não pode".
- **Devolver a coleção inteira sem paginação.** Funciona com dez itens e derruba o servidor com cem mil. Defina um limite máximo.
- **Mudar o formato da resposta sem nova versão.** Renomear um campo quebra todos os clientes que dependem dele.